Product Requirements

Polycarpic — a virtual Single Family Office

Owner: `product-manager` agent

Status: Approved; refinement passes 2026-11-06 and security rulings folded 2026-11-08 — v1, first initiative (`POLY-V1`)

Version: 1.4 **Last updated:** 2026-11-08

CONTENTS

1. Overview & Problem Statement
    1. High-Level Approach
2. Goals & Success Metrics
3. Non-Goals
4. User Stories & Use Cases
5. Functional Requirements
6. Non-Functional Requirements
7. Design Considerations
8. Technical Considerations
9. Timeline & Milestones
10. Open Questions & Risks
11. Appendix
    1. FAQs

1. Overview & Problem Statement

Why we're building this. The user problem, who feels it, and the desired business outcome.

Problem. The Principal manages personal and family finances — budgeting, investment tracking, and quarterly tax estimation — across multiple legal entities (Person, Trust, Business, plus Household and Holding parents that roll them up) using disconnected spreadsheets and per-provider dashboards. There is no single, continuously updated system of record that shows true financial health per entity, categorizes cash flows by tax treatment, tracks investment lots with accurate book and market value, or reliably estimates quarterly taxes.

Who feels it. The Principal today, as owner/operator across several entities. The Principal's spouse and other household members feel it too, once shared-access (membership) features ship — they co-own jointly-titled accounts and need their own view into household finances without owning the underlying ledger.

Status quo and its cost. Manual spreadsheets and per-provider dashboards (bank and brokerage sites) require hand re-entry and reconciliation — the reason the Principal wants this to grow into a virtual **Single Family Office** rather than continuing to patch spreadsheets together. A related prior project, mosko-fintech, explored some of this ground but is explicitly not the blueprint: this project starts from what the Principal wants and doesn't want (kickoff §3), not from that codebase's structure.

Business outcome. A self-hosted system of record with a genuine double-entry general ledger, automated provider-agnostic transaction import, and per-entity dashboards — replacing manual reconciliation with always-current visibility into net worth, cash flow, and tax position across every entity the Principal controls. Built so any self-hoster can run their own instance; the Principal will not host it for others — refer to Item 10 in Section 3 (Non-Goals).

1.1 High-Level Approach

The rough shape of how we'll tackle the problem — a sentence or two so a reader can squint and see the same solution. Not a design or architecture; just the framing. (e.g. for "feature discoverability" → "an in-app notification center for relevant new features".)

A modular, layered SvelteKit application on a genuine double-entry general ledger in PostgreSQL under row-level security. Transactions arrive through provider-agnostic import adapters (a deterministic fake source first, then files, a free direct API, Plaid, and SimpleFIN as a fallback), land as immutable posted journal entries once confirmed, and surface through Monarch/Origin-style per-entity dashboards. Delivered incrementally by initiative — this PRD scopes the first initiative (`POLY-V1`); later initiatives (stock research, Monte Carlo modelling, a consolidated

household dashboard, multi-currency processing, etc.) are explicit Non-Goals for now (§3). Detail belongs in ARCH.

2. Goals & Success Metrics

What measurable outcomes prove the product succeeded? Mix measurable (metrics) and immeasurable (feelings). Include counter-metrics where relevant. Ideally in priority order.

1. **Replace spreadsheets as the system of record.** Metric: by day 90 after POLY-V1 ships, 100% of the Principal's transactions for at least one entity flow through import → draft → confirm, with zero manual spreadsheet entries for that entity — provisional. The real-data path to this goal is file import; it does not depend on any aggregator. Counter-metric: the manual-correction/reversal rate stays low enough that reconciling in-app isn't more work than the prior spreadsheet — numeric threshold TBD.
2. **Quarterly estimated-tax payments land right.** Metric: quarterly transfers into the prepaid-tax accounts (§5) match the app's guiding figure, and at filing there is no underpayment penalty. Refund/balance-due tolerance is set after the first full tax year from observed data. (Comparing to a manual calculation was dropped — filing stays in tax software, and the comparison measured nothing.)
3. **Cash in Transit stays fully explained.** Metric: every approved open item in the *Cash in Transit* clearing account, and every staged unmatched transfer-leg draft, is a known in-flight transfer at each check, with zero of either older than a configurable aging threshold (default 3 business days) — aged items surface on an exceptions report instead.
4. **Self-hosting cost stays low** — a guardrail, not a growth goal. Counter-metric: monthly third-party spend stays near zero beyond the VPS and any data providers actually in use (Plaid trial items, Resend). No dollar figure set yet.

3. Non-Goals

Explicitly out of scope — and why. Non-goals are as clarifying as goals: they shut down ambiguity, prevent scope creep, and make trade-offs visible.

1. Stock research and valuation engine for screening — deferred; not needed until the core ledger and dashboards exist.
2. Monte-Carlo portfolio survivability and efficient-frontier modelling — deferred; depends on real historical data already flowing through the ledger.
3. Capitalization table per entity — deferred; only relevant for entity types that issue units, none of which are in the first initiative.
4. Business-type features (literal inventory management, etc.) — deferred; the first initiative targets Person/Trust budgeting and investing, not business operations.
5. Consolidated roll-up view for any parent entity (Household or Holding) — a parent that owns its own accounts gets the ordinary per-entity dashboard from the first initiative; the view that sums the entities beneath it and the parent's own accounts is a planned quick follow-up milestone immediately after the first initiative, though the schema (parent link + membership) ships first.
6. Multi-currency process (rate feed, period-end revaluation, FX reports) — schema-ready (every journal line already carries currency + native/base amounts) but the process is deferred until foreign currency is actually held again.
7. User-authored report scripting — deferred until the declarative report definitions (§5) prove insufficient for a named report.
8. Period locking of closed books — deferred; the posting-date check is designed so locking can be added later without a schema change.
9. An MCP server exposing a user's data to their own assistant — feasible later as a thin client of the same API, authenticated with the user's own token; out of scope until the API exists.
10. A hosted, multi-user offering run by the Principal — a **standing** non-goal, not a v1-only deferral: the app is built to be self-hostable by anyone, but the Principal will never operate it as a service for others. If that decision is ever deliberately reversed, GLBA Safeguards Rule, state financial-privacy law, and PCI DSS (if card data is ever touched directly) would likely apply (SecEng read, `temp/seceng-research-notes.md`).

4. User Stories & Use Cases

"As a <persona>, I want to <action> so that <outcome>." Aim for 3–8 stories on v1.

1. As an invited household member (or the instance operator on first sign-in), I want to create my account from an invite and land directly in my finances, so that joining a self-hosted instance takes one step and never dead-ends. There is no public sign-up and no setting that reopens it: access is invite-gated, with Google, Apple, GitHub or email + password as the sign-in methods. Owners and managers add a second step (authenticator app or passkey) when they join; viewers may. Acceptance: an invitee joining as owner or manager cannot reach the entity until the second step is enrolled; Google, Apple or GitHub sign-in does not skip it; the operator can issue a standalone invitation from the box for someone who shares no entity yet; and on a home box reached by a `.local` name, Google, Apple and GitHub sign-in are not offered and sign-in is email, password and the second step.
2. As the Principal, I want a dashboard of financial health per entity (Person, Trust, Business, Household, Holding), so that I can tell at a glance how each entity is doing without opening separate spreadsheets or provider sites.
3. As the Principal, I want my bank and brokerage transactions imported automatically and staged as drafts, so that I can review and confirm them instead of hand-entering every transaction.
4. As the Principal, I want categorized expense and revenue cash flows tagged by tax treatment, so that I can distinguish tax-consequence expenses from owner draws/distributions when tax season comes.
5. As the Principal, I want a continuously updated view, per entity and jurisdiction, of my pending tax liability, the required safe-harbor payment, and the gap between them, so that I know exactly how much to wire by each due date without doing the calculation by hand.
6. As the Principal, I want lot-based tracking of my marketable securities with both GL book value and daily market value, so that I can see accurate cost basis alongside current net asset value.
7. As the Principal, I want a balance sheet by GL account and a separate one by custodial (physical holding) account, so that I can reconcile what the ledger says against what my custodians report.
8. As the Principal, I want an asset-allocation view with target adjustments, so that I can see how my actual holdings compare to where I want them.
9. As a household member with a granted viewer role, I want to see the household's shared accounts and my own entity's finances, so that I have visibility into our joint financial picture without owning the underlying ledger.

10. As the Principal, I want a cap table on every entity and an economic view beside the gross roll-up, so that a Household with separate property reads as my share of net worth, and I can see who owns what independently of who can see or edit it.
11. As an owner of an entity with co-owners, I want inviting members, raising roles, removing or demoting a co-owner and editing the cap table to need every other owner's approval, so that no single owner (least of all a zero-unit bookkeeper) can admit anyone or rewrite ownership alone. Acceptance: the change stays pending, with the invite email held, until every other owner approves; a request unanswered for 14 days expires as declined; a sole owner is unaffected and adds the first co-owner alone; the entity's founding owner can force a co-owner's removal after a decline or expiry, and every owner is told.
12. As an owner of an entity placed under a parent, I want to know exactly what the parent's members can see and to be told whenever someone is invited to a parent above my entity, so that my consent is honest and I can pull out. Acceptance: placement and the notices carry the plain-language sentence in §5; each owner beneath is notified once per new parent member, with a pull-out link.
13. As an entity owner, I want every export of the books to carry the ledger's current fingerprint, so that I can later prove the books I kept are the books the system held. Acceptance: each export shows the fingerprint; a permanent delete records the final one; a weekly check emails the owners only if the ledger has been altered.
14. As the Principal, I want the tax accrual trued up at each reporting-period close (monthly by default), so that liabilities show on the balance sheet through the year rather than as one lump at year end.
15. As the Principal, I want time-series charts to show inflation-adjusted values alongside nominal ones, so that growth in net worth, spending and income reads in real terms.

5. Functional Requirements

What the system shall do. Implementation-agnostic.

- The system shall show a dashboard of balances, cash flow, and recent activity per entity, filtered to the entities the logged-in user holds a membership on.
- The system shall create a Person entity named after the user, with an owner membership, at account creation; it is the base unit for personal custodial accounts. There is therefore no no-membership state and no membership-setup screen: an invited user lands on the invited entity, or otherwise on their own Person entity. Account creation is invite-gated via Google, Apple, GitHub or email + password. There is no public sign-up and no setting that reopens it; after the first (operator) user, invitation is the only way in, and the operator can issue a standalone single-use, audited invitation from the box for a person who shares no entity yet (they receive only their own Person). See SECURITY §4.1.
- The system shall require a second sign-in step (authenticator app or passkey) for owners and managers and leave it optional for viewers. A viewer promoted to manager or owner enrols before the new role takes effect. A user whose only entity is their own unshared Person enrols nothing at sign-up; they set up the second step before creating another entity, sharing their Person, or their first export, purge, grant or bank link. Setting up the first second step also confirms a code sent to the account email, and a user with no second step deletes their account with the password plus that code. Google, Apple and GitHub sign-in never skip it. It is asked on a new device and again before risky actions (export, purge, granting access, linking a bank); a known device asks nothing until the session expires. On a home box reached by a `.local` name, Google, Apple and GitHub sign-in are unavailable and sign-in is email, password and the second step. See SECURITY §4.1.
- The system shall import transactions from at least one provider adapter (a deterministic fake source first) behind a provider-agnostic interface, and stage them as drafts pending user confirmation.
- The system shall post a draft transaction as a journal entry on user confirmation, at which point the source transaction becomes immutable (no further update or delete).
- The system shall correct a posted transaction only via a reversing entry plus a new entry, never by editing the original.
- The system shall categorize transactions by expense/revenue category and by tax-treatment tag.
- The system shall maintain a running accrual, per entity and jurisdiction, that annualizes income to date by tax treatment through the applicable rates, and shall derive from it, on any day: (1) the **pending liability** — 100% of annualized tax to date minus the prepaid-tax account balance, always shown; (2) two safe-harbor values — a prior-year basis (last year's filed tax ×

100%/110% by income level × the cumulative fraction due at the next due date) and a current-year basis (90% of annualized tax × the cumulative fraction), with the **required payment** set to the lesser of the two minus the prepaid balance; (3) the gap between the required payment and the pending liability.

- The system shall freeze and store each jurisdiction's annualized figure at its period cutoff (e.g. federal: March 31 / May 31 / August 31 / December 31, multipliers 4 / 2.4 / 1.5 / 1), fixing the due amount for the upcoming due date while the running accrual continues into the next period.
- The system shall drive due dates, period cutoffs, annualization multipliers, and cumulative required percentages from a per-jurisdiction, per-filing-year lookup table (data, not code) — e.g. federal 25/50/75/100 (×90% ⇒ 22.5/45/67.5/90), California 30/70/70/100 — so a new tax year is a data row, not a release.
- The system shall export, at filing, the frozen per-period figures (annualized income, tax, cumulative required, amount paid) needed for Schedule AI / Form 2210 and the state equivalent.
- The system shall post each estimated-tax payment as a transfer from a bank account into a prepaid-tax asset account per jurisdiction (a custodial-account record for the tax authority — IRS or the relevant state — with no provider link); at filing, actual liability settles out of that prepaid asset, any shortfall is paid from cash, and any overpayment remains a receivable until refunded.
- The system shall classify each entity by a tax-classification attribute (individual; trust — grantor or non-grantor; business — pass-through or C-corp; parent entity — joint filers or pass-through to members) and use it to route the filing settlement as an income-tax expense (individual, non-grantor trust, C-corp, joint filers) or a distribution/owner draw (grantor trust, pass-through). A parent entity carries the same settable classification: *joint filers* accrues its own tax payable at close; *pass-through to members* is the default for a new Household, and its tagged income is allocated by the entity's cap table (below), who accrue the tax. Allocation uses the split in force on each income entry's posting date; the units held by outside owners are allocated to no one; a joint-filers parent ignores its cap table for tax; and allocation passes one level onward through a holder that is itself an entity. Realised gains are booked by holding period (short-term, long-term); tax is accrued per jurisdiction at the close, not at the gain. The accrual is trued up at each reporting-period close — monthly by default, quarterly as a per-entity setting — and each true-up is user-confirmed; nothing is posted per journal entry or deferred to year end. Between closes the balance sheet shows a computed, labelled "estimated tax since last close" line, so net assets are right on any day. A pass-through or grantor entity accrues nothing itself. Prior-year filed tax is entered by the user per entity, jurisdiction and year, with the ledger's settled-filing figure shown beside it as a check once it exists.

- The system shall organise the chart of accounts under Assets as four nature classes — Cash and cash equivalents, Fixed income securities, Marketable securities, Alternative investment assets — with a sub-account per custodian; a custodial account is a record of its own (institution, account type, number mask, provider link) that groups those sub-accounts for reconciliation. A custodian sub-account is named by institution plus account type (for example "Schwab brokerage"), with the number mask added only when one institution holds two of a type; the custodial account record keeps its own name. Real estate, and any asset with no custodian and no lots, is an asset account beside the four classes rather than inside one: it counts in net worth and the balance sheet, is excluded from Allocation's classes and targets, and carries a user-booked value with no lots and no reconciliation. Allocation's top level reads these nature accounts and so ties to the ledger; its sub-categories stay editable and unmapped holdings show as a visible gap.
- The system shall track marketable-security lots per custodial account, recording book value (with depreciation/amortization/return of capital) and daily end-of-day market value.
- The system shall render a balance sheet by GL account and a separate balance sheet by custodial account, including the custodial NAV's delta from the prior book period.
- The system shall render an asset-allocation view comparing actual holdings to a user-set target allocation.
- The system shall recognize two raw transaction legs as one inter-account transfer at the import layer (matching within a configurable date window) and post them as one multi-leg journal entry when both legs share a posting date, or as two entries through a seeded *Cash in Transit* clearing account when dates differ (source-date entry debits Cash in Transit / credits the source account; destination-date entry debits the destination account / credits Cash in Transit) — a journal entry always has exactly one posting date. An unmatched transfer leg stays a staged draft (not a journal entry) in the review inbox until its counterpart arrives and the pair is matched, or the user explicitly approves it into Cash in Transit as a one-sided in-flight item; drafts and Cash in Transit items older than a configurable threshold (default 3 business days) appear on an exceptions report. On a transfer between two entities the user chooses how it is booked — contribution / distribution (preselected) or due-to / due-from — and each choice is described in plain language at the point of choice: what it does to both entities' balance sheets, and that due-to / due-from expects repayment. Imported transactions group into one entry only within a single bank date.
- The system shall reconcile the GL balance of each custodial account against the custodian's reported balance. Staged drafts not yet approved are a known unposted delta between the GL and the custodian, shown as such — not a reconciliation break.
- The system shall enforce that every journal entry's debits equal its credits, in the base currency.

- The system shall provide the seeded report templates: Balance Sheet, Income Statement, Statement of Cash Flows, custodial NAV, and NAV delta.
- The system shall grant data access only through a user's membership on an entity (role: owner, manager, or viewer), never through a bare user identifier; a parent entity's structure (e.g. Household over Person) never implies transitive read access — only an explicit membership grant does. A viewer on a parent entity sees the parent's consolidated figures; drilling through into an included base entity stops at that entity's boundary unless the viewer also holds a membership on it, and the UI says so explicitly.
- The system shall support five entity types: Person, Trust, and Business (base entities, which have no children) and Household and Holding (parent entities, which roll up other entities). Any entity may hold accounts, parents included — a Household can hold a joint account. Holding is the generic parent for structures that are not a household (holding structure, estate, family office). A parent entity includes whole entities, never individual accounts; an entity may belong to more than one parent; and a parent may include base entities and other parent entities, to any depth (e.g. a Holding over several Households), provided the structure stays acyclic — an entity can never be its own ancestor. A roll-up at any level sums every base entity beneath it plus the parent's own accounts, counting each entity once even if it is reachable by more than one path. The roll-up shows class totals plus income and expense by top-level category — no account, entry or position.
- The system shall treat placing an entity under a parent as the owner's grant, and say what it grants in these words: **members of the parent, and of any parent above it, see class and category totals for any period, which for a small entity effectively reveals individual amounts and dates, and never a payee, memo, account or counterparty.** Placement is a confirmation of that sentence, and no date range is withheld. Agreeing to a parent also accepts its later placement under other parents, and every owner beneath is notified of that placement and also whenever anyone (in any role) joins a parent above their entity, at any depth; each notice names the parent and the new member, repeats the sentence, and links to pull the entity out. Nothing waits for approval. Either owner of a link may remove it, and the owner of a child entity sees the names (only) of the parents that include their entity.
- The system shall keep a **cap table** for every entity: a total unit count and effective-dated holder rows. Holders are Persons, Trusts or Businesses, never users or parent entities. Units held sum to at most the total; the remainder is held by outside owners. A Person's own table is implicit. Only an owner edits it; history is append-only and each change carries an effective date; a holder is notified when added or changed, and on an entity with more than one owner an edit follows the approval rule below. A holding that would make an entity its own holder, directly or through a chain, is refused, and in v1 so is a chain of more than one entity-to-entity link. A new entity starts at 100 units, all held by the creator's own Person. When an entity that

held units in another entity is permanently deleted, the other entity's cap table shows that holder as "Former holder (purged <date>)", its units count as outside owners from that date, and its owners may type a label of their own for it.

- The system shall keep equity independent of access. The three roles are unchanged (owner controls the entity, manager keeps the books, viewer reads); any role, or none, may hold units. An owner holding zero units is a bookkeeper. A holder with no access may be offered the viewer role.
- The system shall, on an entity with more than one owner, apply these only once every other owner has approved: inviting a member or raising a role (the invite email is sent only then); removing or demoting a co-owner; editing the cap table. A request unanswered for 14 days expires as declined, with a reminder at day 7; a departing owner's approvals stop counting. Removing a viewer or manager, and lowering one's own role, stay single-owner actions, and a sole owner adds the first co-owner alone. Each entity has a **founding owner** (its creator), who must hold the owner role: after a co-owner's removal or demotion is declined or expires, the founder may force it, with the second step, and every owner including the target is told. The founder has no other extra power, hands the role over before leaving it, and names a successor among the owners when deleting their account. See SECURITY §4.2.2.
- The system shall offer an **economic view** (POLY-1.1) beside the gross roll-up, in which every figure is weighted by the viewer's stake, including an economic net worth. It weights only the entities the selected parent's gross roll-up already shows, each counted once; an entity outside that parent contributes nothing, and an entity weighted at zero is shown as such. It reveals nothing the gross view does not. A cross-parent "my net worth" is a later option subject to security review.
- The system shall store aggregator credentials (provider access tokens/URLs) encrypted at rest, exclude them from logs and API responses once stored, and provide a documented path to revoke a linked account's token at the provider, not just delete the local row.
- The system shall let a user export their own personal data, and let an entity owner export the entity's complete books (all accounts, journal entries, lots, raw imports, attachments) in an open format. Every export carries the ledger's current fingerprint (a hash chain over the entry history); a weekly check emails the owners only if the chain is broken.
- The system shall, on a user's request to delete their account, remove that user's credentials, profile, sessions, and memberships; revoke and delete the aggregator tokens that user linked (at the provider, not just locally); and rewrite the actor attribution on entries that user posted to an anonymous tombstone ("deleted user") rather than deleting the entries. The system shall, before deleting an account, list every entity where that user is the sole owner and require the user to choose, per entity, one of: transfer ownership to a named existing member; delete the entity's books through the purge path (mandatory export and retention warning apply); or

abort the whole deletion. The account is deleted only once every such entity is resolved; entities with another owner are untouched, and transfer is never the default or automatic. A user who founded an entity with other owners names a successor founder among its owners as part of the same flow.

- The system shall, when an owner is removed from an entity that keeps at least one other owner, notify every remaining member; nothing waits on them.
- The system shall let an entity's sole owner purge that entity's books entirely — accounts, posted journal entries, drafts, lots, raw imports, attachments — only after a mandatory export step and an explicit warning about the owner's own record-retention obligations. The purge has no waiting period: the guards (fresh re-login, typed entity name, fresh export) apply at the moment of the request, every member is notified immediately, and the entity's final ledger fingerprint is recorded. This is the one path that removes posted rows, and it runs through a privileged, audited procedure, not the ordinary write path.
- The system shall record which actor (a user, an auto-post rule, or a system job) performed each draft or posted journal entry, as a first-class column, never inferred.
- The system shall enforce a tested owner/manager/viewer permission matrix per entity, and keep the RLS session context safe under connection pooling — no cross-tenant reads on a reused connection.
- The system shall maintain a CPI-U reference series (BLS series CUUR0000SA0, monthly) fetched from the Bureau of Labor Statistics API v2 and stored as reference data, with the same ingestion pattern as security price series.
- The system shall render any time-series chart in nominal or inflation-adjusted terms, with a user-selectable base period defaulting to the latest available month.
- The system shall operate without a BLS key (v1 endpoint, lower limits) and accept manual CSV import of the series as a fallback.

6. Non-Functional Requirements

Performance, availability, security regime, accessibility, browser/device support.

Category	Requirement
Performance	Provisional target, accepted by the Principal 2026-09-27: dashboard pages render in <2s on the VPS deployment at single-household data scale.
Availability	Provisional target, accepted by the Principal 2026-09-27: ~99% on a single Hetzner VPS (occasional downtime for patching accepted).
Security / Regulatory	**Audience decision (Principal, 2026-09-27):** the app is self-hostable by others, but the Principal will never host it as a service for anyone else — a standing Non-Goal (§3), not a v1-only deferral. No formal compliance regime attaches for v1: a self-hosted app with no "customer" relationship is not a GLBA/PCI/SOC2-covered entity. GDPR/CCPA-style data rights (export, delete) are adopted as good practice regardless of legal trigger, scoped to the immutable-ledger model (posted journal entries are never edited or deleted through the ordinary write path; the only removal is whole-entity purge by its sole owner). Re-open the regulatory question only on a deliberate later decision to host for others. Despite no regime attaching, the Principal wants the following as **hard requirements**, not aspirational "good practice": • Aggregator credentials (Plaid tokens, SimpleFIN URLs) encrypted at rest, never logged, never returned in API responses once stored, with a documented provider-side revocation path. • RLS keyed on the membership join `(user, entity, role)`, never a bare `user_id` (kickoff §2.4); proven safe under connection pooling; policies cover every table including staging/draft rows and the securities lot sub-ledger, not just posted ledger tables. • A tested owner/manager/viewer permission matrix — which role can do what, per entity type. • Posted ledger rows are append-only, enforced by a database trigger, not app-logic-only; corrections are reversal-only, never edits.

Category	Requirement
	• An actor column (user / rule / system job) on every journal entry and draft row — who or what performed each action is never inferred. • Documented volume/full-disk encryption and encrypted, tested backups with a stated RPO/RTO, plus a novice-operator runbook — the self-host audience is a competent stranger, not a security expert. Packaging consequence: install/upgrade docs and defaults must be operator-proof for a competent stranger running their own instance. Superuser/root Postgres access (which bypasses RLS by definition) is documented as an accepted risk with the instance owner as approver, not something RLS can protect against. Full write-up: `temp/seceng-research-notes.md` (SecEng); detailed controls and threat model belong in SECURITY doc, written in Plan.
Accessibility	WCAG AA target (template default; not separately discussed with the Principal).
Browsers / devices	Modern evergreen browsers (Chrome/Safari/Firefox/Edge) via SvelteKit. Native iOS/macOS clients (Swift/SwiftUI, not a web view) are a later milestone (kickoff §2.10).

7. Design Considerations

Flow diagrams, styled screens, links to Figma. Owned by `ux-designer`.

Full design system, user flows, and styled screens: docs/DESIGN/ (v0.13, 2026-10-20).

- **Brand identity is neon green (`#2CFF05`, the Principal's own choice — "the project name relates to fruiting plants"), used honestly rather than forced onto every surface.** It measures 1.36:1 against white, far below AA. So it stays the literal accent wherever it clears AA (dark surfaces, dark-mode primary), and a darkened same-hue green (`#148100`) serves as the light-mode primary instead. Both choices are stated with measured ratios, not silently substituted. A secondary sky blue (`#05A9FF`) supplies the chart ramp and informational accents. The light-mode canvas is a near-neutral warm off-white (`#F9F8F8`), and every hover fill uses one token (`--accent`). Full derivation: design-system-spec.md § Foundations.
- **Visual identity built from measured references (Monarch Money, Origin at `useorigin.com`), deliberately diverging from polycarpic's own cairn tooling** — one grotesque sans family confirmed against both products' actual app UI (their serif accent is marketing-only), Origin's uppercase mono labels adopted for section headers, and a three-tier status vocabulary (normal/caution/danger). Full rationale and correction history: design-system-spec.md § Inspiration.
- **The app shell is shadcn's sidebar-07 block: a floating sidebar card that inverts relative to the page mode** (dark card in light mode, light card in dark mode). It has a 16px gutter on every side, the brand on top, seven nav items, and an avatar menu at the bottom that opens to the right. There is no persistent header. A top row scrolls with the page: breadcrumb on the left, entity selector and a per-page "more" menu on the right. **The sidebar collapses to an icon rail, and the expand/collapse control lives in the sidebar's own brand row** (the gemini.google.com pattern, decided pass 12):
  - Expanded: a `panel-left-close` icon sits right-aligned beside the logo.
  - Collapsed: the logo mark itself is the expand button. It swaps to `panel-left-open` with an "Expand sidebar" tooltip on hover or keyboard focus.

  Every icon is Lucide. See design-system-spec.md § Sidebar.
- **Color is never the only signal for a financial delta.** Every gain/loss and status indicator pairs color with a sign character, arrow, or icon — a hard requirement given how central gain/loss reading is to this product, not a style preference (WCAG 1.4.1).
- **Entity/account/transaction categories are distinguished by label + icon + badge weight, not per-category hue** — avoids an ever-growing, CVD-fragile categorical palette as the product adds tax-treatment tags and transaction categories over time.

- **Immutability is visible, not just enforced in the data model.** A posted transaction never offers an edit affordance. The user's action is "Correct entry", which posts a reversal plus a replacement entry underneath. The row then carries a "Corrected" badge, and clicking through shows the struck original, the reversal, and the new entry. The interaction mirrors the ledger's own append-only guarantee (§5), so a user never expects an edit that the system will refuse. See design-system-spec.md § Correcting a posted entry.
- **Five flows sketched for the highest-traffic stories** (dashboard glance; transactions review, match & correct; tax liability & safe-harbor; custodial reconciliation, lots & allocation; entity switch & membership access) — docs/DESIGN/#flows.
- **Every page is a styled screen, not a wireframe** (pass 13). The full app renders on the real tokens, shell and components: Dashboard, Transactions, General Ledger and its account register, Custodial Accounts, Allocation, Reports, Entities, Settings, Home, Login, Get started, Sign up, Tax, and the operator-only Admin page. Each is checked in light and dark at 960px and 1280px. They are the visual-regression reference and `frontend-lead`'s head start. Every region maps to a shadcn-svelte component or block in the reuse map. See docs/DESIGN/#screens.

8. Technical Considerations

Known integrations and constraints. Detail lives in ARCH.

- Database: PostgreSQL (latest) — the ledger and RLS live in our own Postgres; no external ledger service, plain-text ledger engine, or full ERP.
- Auth: BetterAuth in our Postgres; OAuth day one via Google, Apple, GitHub; second step (authenticator app or passkey) required for owners and managers; transactional email via Resend.
- Frontend: SvelteKit + shadcn-svelte (Tailwind, LayerChart for charts); design tokens come from DESIGN once built.
- Hosting: primary Hetzner VPS via Docker Compose (self-owned box); secondary a user-owned and managed Linux box on a local network with no internet exposure — the maximum-security option, the same Docker Compose deployment shape as the Hetzner path but with no public ingress (outbound-only: it may reach the internet for updates, aggregator pulls, and outbound email but accepts no inbound connection from it; UI and OAuth callbacks are reached only from LAN browsers; backups leave the box encrypted; SECURITY specifies the detail); tertiary Vercel + Neon, the serverless free-tier last resort, kept working and CI-verified. These are deployment targets, not separate architectures.
- Repository: pnpm workspace monorepo (`apps/web` , later `apps/ios` ; one `packages/` per layer) with affected-only CI; OpenAPI generated from route schemas.
- Import providers: provider-agnostic adapter interface; for any custodial the priority of use is (1) file import, (2) a free direct API (e.g. Schwab), (3) Plaid, (4) SimpleFIN — a fallback for institutions Plaid does not cover (e.g. Synchrony), not used or paid for unless a custodial needs it. The implementation order follows: fake → files → direct API → Plaid → SimpleFIN. GA needs the files path working, plus direct and Plaid for the custodials the Principal holds.
- Native clients: Swift/SwiftUI for iOS and macOS (not a wrapped web view), generated from the same OpenAPI spec — a later milestone.
- Tax jurisdiction/rate tables (due dates, period cutoffs, annualization multipliers, cumulative required percentages) are per-jurisdiction, per-filing-year data rows, not code — a new tax year never requires a release; storage mechanism is an architect decision in Plan.
- BLS API v2 requires a free per-operator registration key (500 queries/day); each self-hoster registers their own. The key is a low-tier secret — never logged, never in the repo.

Full rationale, layer boundaries, and API shape belong in ARCH, written next in the Plan phase. Implementation-level detail extracted during this import (GL, transaction-import mechanics, reports engine, infra topology, fake-data generator) is queued at `temp/prd-spillover-arch.md` for the architect.

9. Timeline & Milestones

Coarse milestones (named by target version, e.g. `1.0`). Features are tracked in the cairn tracker (`process/cairn/`, board via `/cairn`); process/STATE.md holds only the current phase and active-feature pointer.

Milestone	Target date	Definition of done
POLY-A — Bootstrap & Tooling	done (2026-09-27)	Repo scrubbed from template, tracker set up, per-agent git identity, path-ownership check, estimation loop in cairn.
POLY-B — Research	*in progress*	This PRD (v1) approved; user stories seeded to the tracker backlog.
POLY-C — Plan	*TBD*	Design system built, throwaway UX prototype at `prototype/`, ARCH doc (layers, GL build-vs-adopt decision, migration tool), SECURITY doc, INFRA doc — all as living artifacts.
Development milestones `POLY-M1`, `POLY-M2`, … under the `POLY-V1` major	open by decision, not omission	Defined by the architect in Plan, ordered by scope not release order (entity/membership model, GL + journal entries, provider-agnostic import with draft→confirm, transfer matching, reconciliation, securities lot sub-ledger, seeded reports, per-entity dashboard). A milestone is renamed to a version (`POLY-0.x` / `POLY-1.0`) only when designated to cut a release, preserving the tracker's 1:1 milestone↔tag rule.
POLY-1.0 — GA	*TBD*	The v1 scope above on staging data, with the files path working and direct and Plaid adapters for the Principal's custodials. A backup restore drill passes — a GA gate, in place of early real data.
POLY-1.1	*TBD*	The economic view beside the gross parent roll-up (cap-table-weighted figures and economic net worth), scoped to the selected parent's roll-up set.

Dates are open by deliberate decision, not omission: this is a self-paced personal project. Estimates come from the tracker's observed baseline after the first development milestone, not from a calendar commitment.

10. Open Questions & Risks

Every unresolved question. Every assumption that could be wrong. This drives the next conversation.

- Resolved (Principal, 2026-09-27): the app is self-hostable by others but the Principal never hosts it as a service — a standing Non-Goal (§3), not a v1-only deferral. No compliance regime (GLBA/PCI/SOC2) applies for v1 as a result (SecEng, §6). Re-open only on a deliberate later decision to host for others.
- Resolved (Principal, 2026-09-27): timeline is fully self-paced — milestones ordered by definition of done, no target dates. Estimates come from the tracker's observed baseline after the first development milestone (§9).
- Plan-phase: credential-encryption mechanism (envelope vs. pgcrypto vs. external secrets manager) and key rotation for a self-hoster with no KMS; how RLS session context is set safely under connection pooling; the owner/manager/viewer authorization test matrix; backup-encryption key custody; the privileged whole-entity purge path (§5) — how it coexists with the append-only trigger (disable-in-transaction vs. separate role vs. tombstoning), and how it is audited. See `temp/seceng-research-notes.md` — feeds SECURITY doc.
- Plan-phase: general ledger — build a home-grown schema (borrowing from mosko-fintech) vs. adopt a library that manages tables inside our own Postgres (kickoff §2.5), owned by the architect.
- Plan-phase: database migration tool — Drizzle is the leading candidate; the architect confirms against the `mosko-fintech` incumbent (kickoff §2.13).
- Plan-phase: bloat-signal thresholds (gate cycles over estimate, token ratio) are set only after the first milestone's baseline (kickoff §2.12) — no number yet.
- Resolved (Principal, 2026-11-06): the first slice is stories 1 and 2 (invite sign-in, per-entity dashboard) plus transaction import via the fake source. The architect and team-lead still break `POLY-V1` into milestones/issues.
- Not an assumption — needs the Principal's CPA: confirm trust (grantor vs. non-grantor) and pass-through filing treatment for the Principal's actual entities before the tax-classification attribute (§5) is relied on (ruled 2026-11-06: the attribute ships as a per-entity settable field; nothing blocks on the confirmation). Follow-up on this item: a combined filing group across a Household and its Persons on one joint return is not in v1.
- Resolved (Principal, 2026-11-07, folded in v1.4): second sign-in step required for owners and managers; no switch reopens public sign-up; a `.local` home box has no Google, Apple or GitHub sign-in; parent members see totals for any period under an explicit consent sentence; owners beneath are notified when anyone joins a parent; multi-owner changes need every other owner's approval with a founding-owner tie-break; exports carry a ledger fingerprint; a

purged holder reads "Former holder". Rulings in `process/DECISIONS.md`; rules in SECURITY §4.1, §4.2.2 and §4.6.

- Assumption (ruled 2026-11-06): no real books exist before v1.0. Until then everything runs on staging; the Plaid Sandbox (and SimpleFIN demo access) feeds staging through the real adapters, with the deterministic fake source as the repeatable fixture. A backup restore drill is a GA gate. Early testing may be fake and files only until the Plaid adapter lands.

11. Appendix

Research notes, competitive analysis, supporting links.

- Source documents: docs/project_kickoff.md (operative kickoff record) and docs/project_manifesto.md (original brief, frozen as written) — both imported into this PRD via `/generate-prd`. Kept in place rather than moved to `docs/archive/`, per team-lead ruling: `CLAUDE.md` links both by their current paths and calls the kickoff record operative.
- Reference project: mosko-fintech — prior related work, explicitly not the blueprint for this project.
- Look-and-feel references: Origin, Monarch; starting layout: shadcn-svelte dashboard-01.

11.1 FAQs

Optional. Short Q&A pairs that help a newcomer grasp the project without reading the full PRD. Great place to capture "wait, why didn't we just…" questions that came up during Research.

Q: How do I add review comments to this PRD?

A: Two ways. Hand-edit `docs/PRD/comments.md` with `## §<section-id>` blocks pointing at the `id` attribute of the section you're commenting on. Or run `./scripts/serve-docs.sh` from the repo root and browse to `http://localhost:8765/PRD/` — an inline widget appears next to each section heading with a `+ Comment` button. Both methods write to the same `comments.md` file. When you're ready for Claude to act on the comments, run `/refine-doc PRD` — each comment is addressed in the matching section and removed from the sidecar. The sidecar is gitignored; the actual resolution lives in this doc and is committed via PR. See process/WORKFLOW.md → Doc review loop for the full pattern.

Q: Why aren't `project_kickoff.md` and `project_manifesto.md` archived now that the PRD exists?

A: The standard import flow moves a legacy source to `docs/archive/` once ported. Team-lead ruling keeps both in place instead, since `CLAUDE.md` links them by their current paths and calls the kickoff record operative; they'll be frozen as history once the PRD and ARCH doc fully absorb their content, per the kickoff file's own header.

Q: Does a Household have a dashboard in the first initiative?

A: Yes, if it owns accounts of its own (e.g. a joint checking account) it has a normal per-entity dashboard from day one. Only the view that sums the entities beneath it (the roll-up) follows as a planned quick milestone right after the first initiative.

Generated by the `product-manager` agent via `/generate-prd`. Edit by re-running the skill or editing in place.